TOURSHIELD

API de Turismo e Reservas

Consolidação e transição preditiva

Projeto de Bloco | Trabalho Prático 3

Helena Gomes
25 de outubro de 2026

Competência integradora: consolidar o sistema estatístico e a API segura, documentando a transição para a fase preditiva.

Regressão didática	Segurança e CI	Planejamento T2
R^2 teste: 0,879	47 testes aprovados	TF-IDF + classificação
RMSE: 1,31 palavra	Check exigido na main	20 intenções definidas

A API permanece sem modelo de classificação e sem novas funções de negócio. /docs e CI consolidam a base para o laboratório de pentest.

Pendência externa declarada: colega adversário, URL/IP da API e confirmação de acesso ainda não foram definidos. A aluna solicitou concluir os demais itens; essa confirmação não foi inventada.

github.com/lenagomesz/tourshield-api-pb-tp1

01 / Consolidação do Trimestre 1

Componente	Estado consolidado
Dados	CLINC150, recorte TourShield de 3.000 mensagens em inglês, 20 intenções, licença CC BY 3.0.
Qualidade	Shape original (3.000, 4), limpo (3.000, 6). Zero ausentes, duplicatas normalizadas ou conflitos; nenhuma linha removida.
Splits	2.000 treino / 400 validação / 600 teste, preservados desde TP1.
EDA e estatística	Histogramas, barras, boxplot, correlações, scatters e teste Mann-Whitney de reservas/localização no TP2.
API v0.3.0	FastAPI, JWT/Argon2, SQLModel, ownership, extra=forbid, headers, CORS e limite de autenticação.
Transição	Regressão numérica didática separada da API; classificação de intenção planejada para T2.

A EDA do TP2 encontrou Pearson 0,935 entre caracteres e palavras e diferença exploratória de comprimento entre reservas e localização. Os achados ajudam a formular experiências, mas não resolvem classificação nem fraude.

Por que o pivô é necessário

Análise descritiva explica composição e limitações da base; regressão mostra um problema numérico; o futuro classificador responderá qual intenção corresponde à mensagem. São objetivos e métricas distintos.

Permanecem as limitações: crowdsourcing, idioma inglês, intenção única, balanceamento artificial, autores desconhecidos e ausência de GPS, transações ou fraude confirmada. Os dados de teste já foram descritos na EDA; será necessária confirmação externa.

Fonte: Stefan Larson et al. (2019), CLINC150, github.com/clinc/oos-eval. Atribuição, licença, revisão e hashes estão em data/ e no manifesto de proveniência.

02 / Pipeline de regressão linear

Alvo: n_words, número de palavras delimitadas por espaços. Baseline pela média do treino, regressão simples por n_chars e regressão múltipla por atributos textuais. Experimento didático, sem acionar /predict.

```
ColumnTransformer (features numéricas)
  -> SimpleImputer (mediana do treino)
  -> VarianceThreshold (remove constantes)
  -> StandardScaler (ajustado no treino)
  -> LinearRegression
```

Preditores propostos: caracteres, dígitos, pontuação e proporção de maiúsculas ASCII. A última é constante zero no treino e foi excluída pela pipeline. A múltipla mantém três variáveis. Intenção, ID, split e n_words não entram em X; comprimento médio da palavra é omitido para não reconstruir o alvo diretamente.

Resultados no teste - 600 mensagens

Modelo	R^2	RMSE (palavras)	MAE (palavras)
Média do treino	-0.0116	3.7874	3.0443
Linear simples	0.8747	1.3331	1.0559
Linear múltipla	0.8789	1.3102	1.0401

A múltipla melhora pouco sobre a simples: ΔR^2 aproximadamente 0,0043 e redução de RMSE de 0,023 palavra. Não exagerar importância prática. O baseline pode ter R^2 negativo porque usa a média do treino, não a média do próprio teste.

R^2 não é acurácia; RMSE enfatiza erros maiores e tem unidade de palavras. Transformações aprendidas são ajustadas só no treino. Não houve busca de hiperparâmetros, remoção de outliers ou escolha guiada pelo teste.

Coeficientes padronizados são associações: caracteres 3,1976; dígitos 0,2633; pontuação -0,2028 palavra por desvio padrão do treino, mantendo os demais fixos. Não há interpretação causal.

03 / Resíduos e Q-Q plot

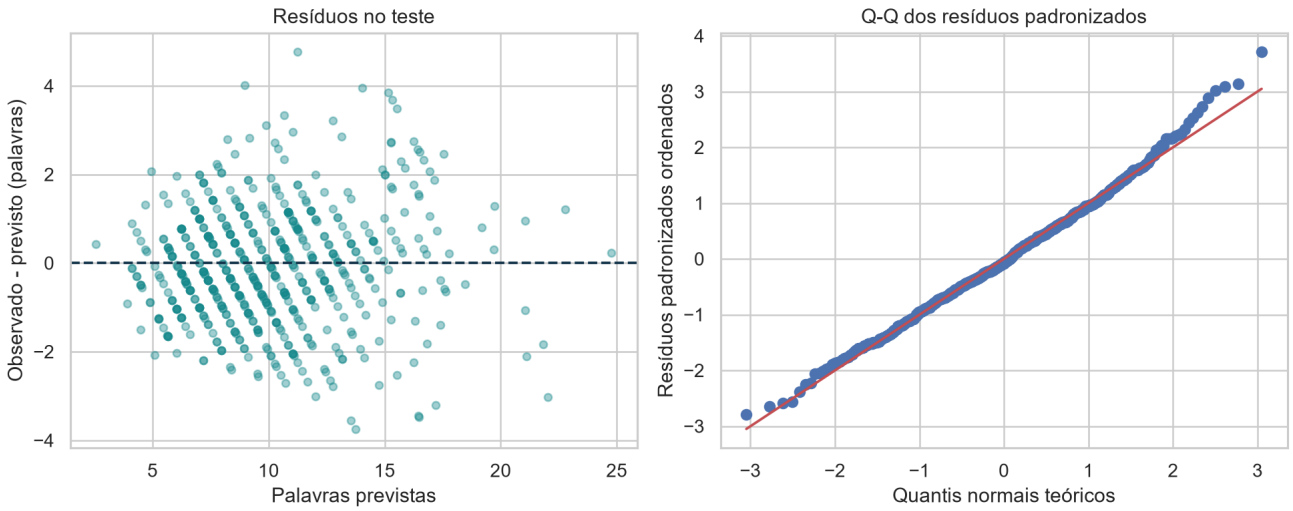


Figura 1. Resíduo observado - previsto e Q-Q dos resíduos padronizados, no teste. Fonte: elaboração própria sobre CLINC150.

As faixas diagonais no residual plot refletem o alvo discreto. Os erros se distribuem em torno de zero, com dispersão variável e alguns extremos. Média residual: -0,0904 palavra, indicando pequena superestimação; DP: 1,3082.

O Q-Q acompanha a reta na região central e se desvia nas caudas, principalmente na superior. Assimetria 0,2636 e excesso de curtose 0,3521 não demonstram normalidade exata. Não foi realizado teste formal de homoscedasticidade; a correlação descritiva entre |resíduo| e previsto é 0,1611.

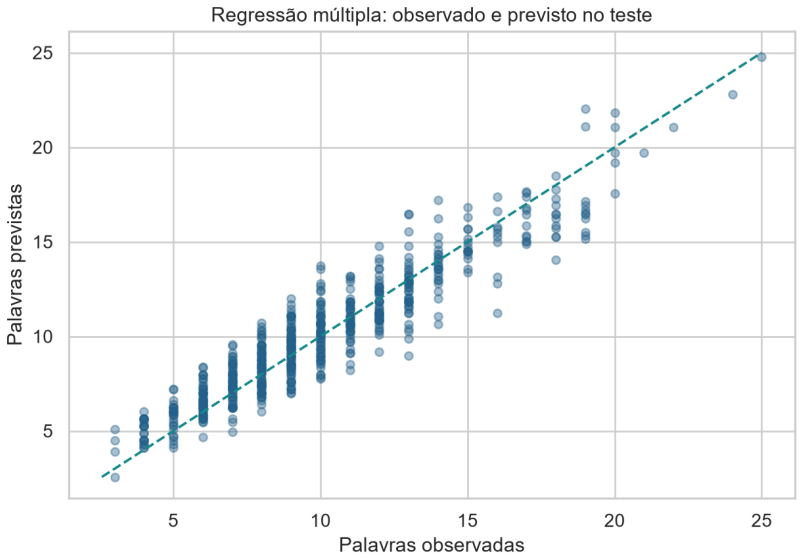


Figura 2. Observado e previsto; linha tracejada indica igualdade. A dispersão mostra erros mesmo com R^2 elevado.

04 / Limitações da regressão

Relação estrutural e utilidade

Caracteres e palavras são medidas do mesmo texto. O R^2 alto é em grande parte explicado por essa relação estrutural. O número de palavras pode ser contado diretamente, sem ML: esta regressão não tem utilidade operacional para encaminhar atendimento.

Limites estatísticos

OLS produz valores contínuos e pode prever frações ou números negativos fora da amostra. Não houve predição negativa no teste, mas isso não garante suporte correto em produção. O Q-Q indica desvios nas caudas e não autoriza intervalos paramétricos sem avaliar premissas.

Normalidade de resíduos não é requisito para calcular previsões lineares; seria relevante para certas inferências e intervalos tradicionais. Não foram estimados intervalos de previsão, causalidade ou significância de coeficientes.

Limites de dados e validação

A proporção de maiúsculas ASCII é constante nesta amostra e não generaliza automaticamente para português. Autores repetidos podem criar dependência não auditável. Validação e teste já foram descritos no TP1/TP2: não constituem amostra externa nova.

Conclusão para a transição

O exercício cumpre a tarefa numérica, mas não responde qual é a intenção do usuário. R^2 e RMSE não medem classificação de intenção, localização física ou fraude. T2 deverá usar rótulos nominais, representação de texto e métricas de classificação, mantendo segurança independente da saída do modelo.

Notebook executado: eda/regression_tp3.ipynb, com fonte equivalente .py e seção Limitações e próximos passos. Métricas por split, coeficientes e resíduos rastreáveis por ID estão em reports/tp3/.

05 / Auditoria final da API

Controle	Status / evidência
Autenticação / BOLA	Resolvido: JWT válido, conta ativa, Argon2 e consulta por ID+owner; sem token 401 e outro usuário 404.
Input / banco	Resolvido: extra=forbid, faixas e limites; SQLModel sem SQL raw.
Headers / CORS / limite	Resolvido: headers também em erros, allowlist, login 5/IP/60s, body 16 KiB e timeout 10 s.
/docs e OpenAPI	Resolvido: Swagger UI 5.34.0 local, sem CDN/inline, CSP específica, assets verificados, sem token persistido.
Dependências	Snapshot pip-audit: 93 pacotes, 0 vulnerabilidades conhecidas. Reavaliar antes de implantar.
MFA / revogação / infra	Aceito no laboratório: sem MFA, revogação individual, limiter distribuído, backup e alertas externos.
Prontidão	Alvo local exercitado com duas contas fictícias; publicação externa e colega confirmado ainda pendentes.

ZAP final: 2.17.0, modo safe, 25 requisições em TLS local, 61 regras passivas, fila zerada; sem spider ou active scan. Incluiu /docs e assets. High=0; Medium=0; Low=33; Informational=10.

Não havia Medium/High pendente do TP2. Os 33 Low são possíveis timestamps detectados em constantes numéricas do bundle público do Swagger, como o vetor SHA-1. Foram revisados e aceitos como falsos positivos; não são datas de sessão/usuário. Nenhuma regra foi suprimida.

Os informativos correspondem a cache intencional, identificação de login/sessão e comentário de biblioteca. Evidências e aceites em reports/zap_tp3/findings.md. HTML e JSON são exportados pelo ZAP, com redação apenas de segredos efêmeros.

Scan passivo inspeciona mensagens exercitadas, sem provar ausência de falhas. O certificado autoassinado é de laboratório; produção requer TLS válido e revisão de implantação. Checklist completo em docs/audit_final_tp3.md.

06 / Testes, CI e bloqueio de merge

Área	Casos executados
Autenticação	401 sem token; senha incorreta; JWT expirado, assinatura/claims/algoritmo inválidos e conta inativa.
Autorização	Reserva própria 200; outra conta 404 igual ao inexistente; owner/status não podem ser atribuídos no body.
Validação	Campo extra, mensagem vazia, GPS inválido/isolado, body grande e erro sem echo de dados.
Rate limiting	Sexta tentativa bloqueada, Retry-After, recuperação por relógio injetado e XFF ignorado.
Documentação / HTTP	Assets e hashes, OpenAPI com segurança, CSP/headers, CORS e /docs sem desativar autenticação.

pytest tests/ -v: 47 aprovados localmente, sem falhas. Evidência em reports/tests_tp3.xml. O aviso de depreciação TestClient/httpx não altera o resultado.

O workflow .github/workflows/security-tests.yml executa em push e pull_request, com Python 3.12, dependências fixadas e permissões contents:read. Não usa continue-on-error; retorno não zero do pytest falha o job. Actions são fixadas por SHA e o XML é publicado como artefato.

A branch main exige o check **security-tests** atualizado (strict=true), inclusive para administradores. Force push e exclusão estão bloqueados. Essa configuração foi lida de volta da API GitHub; apenas criar YAML não impediria merge sem a regra.

Execução real aprovada:
https://github.com/lenagomesz/tourshield-api-pb-tp1/actions/runs/40191034423

Commit verificado: 35e0be9c98d70859e2afa890d2368b370c50d5a5. Snapshot da regra e execução: reports/tp3/ci_evidence.json. A publicação dos documentos finais também deve passar pelo check antes do merge.

07 / Pergunta de classificação (1/2)

Dado um texto de atendimento ao cliente, qual é a intenção do usuário? Entrada: mensagem. Saída: um dos 20 rótulos nominais abaixo. É classificação supervisionada multiclasse de intenção única.

Intenção	Significado	n (%)
book_flight	Reservar voo	150 (5%)
book_hotel	Reservar hotel	150 (5%)
cancel_reservation	Cancelar reserva	150 (5%)
confirm_reservation	Confirmar reserva	150 (5%)
car_rental	Alugar carro	150 (5%)
flight_status	Consultar voo	150 (5%)
lost_luggage	Bagagem perdida	150 (5%)
carry_on	Bagagem de mão	150 (5%)
travel_alert	Alertas de viagem	150 (5%)
travel_notification	Notificar viagem	150 (5%)
travel_suggestion	Sugestão de viagem	150 (5%)
international_visa	Visto internacional	150 (5%)
vaccines	Vacinas para viagem	150 (5%)
plug_type	Tipo de tomada	150 (5%)
current_location	Localização atual	150 (5%)
directions	Orientações de rota	150 (5%)
distance	Distância	150 (5%)
share_location	Compartilhar localização	150 (5%)
redeem_rewards	Resgatar recompensas	150 (5%)
rewards_balance	Consultar recompensas	150 (5%)

Total: 3.000 mensagens. Por classe: 100 treino / 20 validação / 30 teste. Distribuição uniforme é do desenho do benchmark, não da demanda por atendimento. Exemplo semântico futuro: mensagem de reserva de hotel -> book_hotel; não é predição de modelo já treinado.

Documento separado: docs/classification_question_tp3.md. Fonte: Larson et al. (2019), CLINC150, CC BY 3.0.

08 / Pergunta de classificação (2/2)

Justificativa para ML supervisionado

A base contém pares de mensagem e intenção rotulada. Um classificador aprende associações de vocabulário com rótulos e permite avaliar seus erros. Isso oferece um ponto inicial reproduzível antes de modelos mais complexos, sem criar regras arbitrárias de tamanho de texto.

O baseline majoritário tem 5% de acurácia nesta distribuição uniforme. A avaliação deve considerar macro-F1, recall por intenção e matriz de confusão; acurácia sozinha pode ocultar classes confundidas. O modelo deve ser comparado a baselines em splits preservados.

Por que regressão linear é inadequada

Intenções são categorias sem ordem ou distância. Transformar rótulos em números 0-19 faria o erro quadrático tratar uma categoria como mais distante de outra sem fundamento. OLS também pode prever frações e valores fora do conjunto de classes.

A regressão deste TP estima comprimento em palavras: R^2 alto apenas descreve esse alvo numérico. Não mede reconhecimento de intenção nem valida a tarefa de negócio. Regressão logística, apesar do nome, é um classificador que aprende escores/probabilidades por categoria.

Escopo e limites de decisão

O recorte não contempla intenção desconhecida ou múltiplas intenções por mensagem. Não prometer rejeição out-of-scope ou bom desempenho em português sem novos dados. Saldos e resgates são intenções genéricas, não comprovação de fraude turística.

Classificação encaminha atendimento. Não comprova localização, titularidade da reserva ou elegibilidade para benefício. JWT, ownership, saldo e regras de negócio continuarão sendo verificados no servidor, independentemente da predição.

Essas duas páginas formam o documento de pergunta de classificação solicitado; o Markdown separado fornece o mesmo escopo e a distribuição completa.

09 / Planejamento técnico para T2

Decisão	Protocolo predefinido
Candidato principal	Regressão logística multiclasse, regularização L2, solver lbfgs, max_iter=2.000.
Features	Pipeline TF-IDF com lowercase, n-gramas (1,2), min_df=2, max_features=10.000 e sublinear_tf=True.
Pré-processamento	Sem tradução ou stopwords automáticas; preservar negações. Vocabulário/IDF aprendidos só no treino.
Ajuste	Comparar C=0,1; 1; 10 na validação; selecionar por macro-F1 e desempatar pela configuração mais simples.
Baselines / alternativa	Classe majoritária e features de comprimento; LinearSVC como alternativa justificada pela validação.
Avaliação	Macro-F1, acurácia, recall por classe, confusão, latência e tamanho. Congelar decisões antes do teste.
Confirmação externa	Nova amostra autorizada em português, com multi-intenção/out-of-scope; documentar limites do teste já explorado.
Integridade	Artefato produzido pelo projeto, hash e versão; não aceitar pickle/joblib enviado por usuário.

Nenhum resultado de classificação é antecipado. Exigir ganho sobre baseline, registrar convergência e erros, e evitar prometer limiar sem experimento. Não usar ID, split ou intenção codificada como atributos de entrada.

Integração futura

Manter contrato e autenticação de /predict; distinguir modelo indisponível de baixa confiança. CI de segurança deve continuar obrigatório. O classificador não poderá conceder benefício ou executar ferramentas a partir do texto recebido.

Plano completo: docs/t2_plan_tp3.md. A regressão numérica permanece apenas no notebook; não adiciona previsão de negócio à API.

10 / Adversário e prontidão local

Campo exigido	Estado em 25/10/2026
Colega adversário	Pendente - não informado pela aluna
URL ou IP da API adversária	Pendente - nenhum alvo inventado
Confirmação de acesso	Pendente - não recebida
Escopo e janela	Pendente de acordo entre participantes

A aluna informou que esses itens estão pendentes e solicitou concluir o restante. Essa dependência externa não foi apresentada como resolvida. Antes do TP4, registrar nome, URL, data da confirmação e escopo combinado, sem versionar senhas ou tokens.

Prontidão da própria API

O ZAP exercitou a aplicação local com duas contas fictícias e reserva própria/alheia. /health e /docs responderam 200; login funcionou; acesso sem token recebeu 401; outro proprietário, 404; entrada extra, 422; excesso de login, 429. Nenhum pentest foi iniciado contra terceiro.

scripts/seed_pentest.py cria lab_alice e lab_bob em banco pentest.sqlite3, com reservas e senhas aleatórias. As credenciais ficam somente em tmp/pentest-credentials.json, ignorado pelo Git. O script não sobrescreve contas existentes.

Limite da prontidão

Prontidão local de laboratório não é produção nem acessibilidade remota. 127.0.0.1 não pode ser usado pelo colega como alvo público. Exposição externa requer acordo, TLS válido, contas fictícias, configuração de host/proxy e execução sem --reload.

Sequência proposta: definir parceiro/alvo; congelar protocolo analítico; treinar/validar baselines e candidato; avaliar teste; integrar artefato confiável; repetir pytest/ZAP antes da próxima entrega. Prazos dependem do professor.

11 / Execução e evidências da entrega

```
python -m venv .venv
.\.venv\Scripts\Activate.ps1
python -m pip install -r requirements-lock.txt
# Configure .env: segredo aleatório; DATABASE_PATH=./pentest.sqlite3
python -m scripts.seed_pentest
uvicorn main:app --reload --no-proxy-headers --no-server-header
# Em outro terminal:
pytest tests/ -v
python eda/regression_tp3.py
python -m scripts.build_regression_notebook
python -m scripts.run_zap --tp3
```

Evidência	Local
Notebook / métricas	eda/regression_tp3.ipynb; reports/tp3/
Testes / Actions	tests/; .github/workflows/security-tests.yml; ci_evidence.json
Auditoria final	docs/audit_final_tp3.md; reports/zap_tp3/
Pergunta de classificação	docs/classification_question_tp3.md (e páginas 8-9 deste PDF)
Plano T2 / pendência	docs/t2_plan_tp3.md; docs/delivery_tp3.md

Referências

Larson et al. (2019), CLINC150: aclanthology.org/D19-1131, CC BY 3.0.
Scikit-learn: modelos lineares.
FastAPI: documentação com assets locais.
ZAP: API oficial.
GitHub: branches protegidas e status checks.

Repositório: github.com/lenagomesz/tourshield-api-pb-tp1. Enviar o link, PDF e documentos conforme a plataforma da disciplina. A confirmação do adversário permanece pendente e deve ser completada antes do pentest.